

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA GESTIONE DEGLI INCIDENTI ICT

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PRO019_00	00	12/04/2026	7
Redatto da	Approvato da	Classificazione	Stato
IT / RSGI / DPO	AD – Francesco Epifani	Riservato	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
12/04/2026	12/04/2026	12/04/2026

1. Scopo e campo di applicazione

La presente procedura disciplina la rilevazione, la classificazione, la gestione, la risoluzione e la documentazione degli incidenti relativi ai sistemi informativi, alla sicurezza delle informazioni e alla continuità dei servizi IT di Toscana Diagnostica. Un incidente ICT è qualsiasi evento, intenzionale o accidentale, che compromette o minaccia la riservatezza, l'integrità o la disponibilità dei dati, dei sistemi o dei servizi informatici.

La procedura sviluppa nel dettaglio operativo quanto definito nella TD-SGI-PRO016 (Sezione 11), integra gli obblighi di notifica del GDPR (data breach) e del D.Lgs. 138/2024 (NIS 2), e si coordina con la TD-SGI-PRO018 (IT Change Management) per le modifiche di emergenza derivanti da incidenti. Si applica a tutti i sistemi dell'architettura TD (Microsoft 365, GIPOnext, StudioLab, ZeeroMED, infrastruttura WIND, fonia TWY) e a tutto il personale.

2. Riferimenti normativi

Norma / Riferimento	Ambito
ISO 27001:2022, All. A cl. 5.24-5.28	Gestione degli incidenti di sicurezza delle informazioni: pianificazione, risposta, evidenze, lesson learned
ISO 27035-1:2023	Gestione degli incidenti di sicurezza delle informazioni: principi e processo
ISO 27035-2:2023	Linee guida per la pianificazione e la preparazione alla risposta agli incidenti
Reg. UE 2016/679, artt. 33-34	Notifica di violazione dei dati personali al Garante (72 ore) e comunicazione agli interessati
D.Lgs. 138/2024 (NIS 2), artt. 25-26	Obblighi di notifica degli incidenti significativi al CSIRT Italia
D.Lgs. 196/2003, art. 33-bis	Obblighi di notifica nel Codice Privacy
TD-SGI-PRO016	Procedura Sicurezza SI (Sez. 11: gestione incidenti; Sez. 10: BC/DR)
TD-SGI-PRO018	Procedura IT Change Management (Sez. 3: modifiche di emergenza)
TD-SGI-REG003	Documento Informativo AdS (ruoli e obblighi di segnalazione)
TD-SGI-PRO015	Procedura Gestione Rischio Clinico (incidenti IT con impatto clinico)

3. Tassonomia e classificazione degli incidenti

3.1 Tipologie di incidenti

Tipologia	Descrizione ed esempi nel contesto TD	Sistemi potenzialmente coinvolti
Malware e ransomware	Infezione da virus, trojan, worm, ransomware su postazioni o sistemi. Cifratura dei dati con richiesta di riscatto	Postazioni di lavoro, M365 (allegati email), rete interna
Phishing e social engineering	Email fraudolente, impersonificazione, tentativi di carpire credenziali o dati. Compromissione di account M365	M365 (Exchange, Teams), credenziali di accesso a tutti i sistemi
Accesso non autorizzato	Accesso ai sistemi o ai dati da parte di soggetti non autorizzati (intrusione esterna o abuso interno)	Tutti i sistemi: GIPOnext, StudioLab, ZeeroMED, M365, rete
Data breach (violazione dati personali)	Distruzione, perdita, modifica, divulgazione o accesso non autorizzato a dati personali, inclusi dati sanitari	Tutti i sistemi che trattano dati di pazienti: GIPOnext, StudioLab, ZeeroMED
Indisponibilità del servizio	Interruzione di un sistema o servizio IT che impedisce l'operatività clinica o amministrativa	GIPOnext (accettazione bloccata), StudioLab (LIS fermo), ZeeroMED (imaging fermo), M365 (posta ferma), WIND (rete)
Guasto infrastrutturale	Guasto di apparati di rete (firewall, switch, AP), interruzione connettività, guasto alimentazione	Infrastruttura WIND, apparati locali, connettività Internet
Vulnerabilità sfruttata	Sfruttamento di una vulnerabilità nota (zero-day o non patchata) su sistemi o applicazioni	Postazioni (OS non aggiornato), applicazioni, firewall
Incidente causato da change	Incidente direttamente attribuibile a una modifica IT (aggiornamento fallito, configurazione errata)	Qualsiasi sistema oggetto della modifica (rif. TD-SGI-PRO018)

3.2 Livelli di severità

Livello	Severità	Criteri	Tempi di risposta
P1	Critico	Indisponibilità di un sistema clinico core (LIS, RIS/PACS, GIPOnext) con impatto sull'erogazione delle prestazioni; data breach confermato con dati sanitari; attacco ransomware in corso; interruzione totale della rete	Presa in carico: 15 minuti. Escalation AD e DS: immediata. Obiettivo risoluzione: 2 ore
P2	Alto	Indisponibilità parziale di un sistema clinico; compromissione di un account amministrativo; sospetto data breach in fase di verifica; indisponibilità della posta elettronica aziendale	Presa in carico: 30 minuti. Escalation RSGI: 1 ora. Obiettivo risoluzione: 4 ore
P3	Medio	Malfunzionamento non bloccante di un sistema (rallentamento, errore intermittente); tentativo di phishing intercettato; singola postazione compromessa e isolata; guasto AP Wi-Fi	Presa in carico: 2 ore. Obiettivo risoluzione: 8 ore lavorative
P4	Basso	Anomalia minore senza impatto operativo; spam aumentato; richiesta di assistenza tecnica; aggiornamento fallito su postazione singola	Presa in carico: 4 ore lavorative. Obiettivo risoluzione: 2 giorni lavorativi

4. Processo di gestione degli incidenti

4.1 Fase 1 – Rilevazione e segnalazione

La rilevazione può avvenire da diverse fonti: segnalazione di un utente (email, telefono, Teams a IT); alert automatico dei sistemi di sicurezza (EDR, firewall IPS/IDS, Microsoft Defender); notifica da parte di un fornitore SaaS (GIPOnext, StudioLab, ZeeroMED, WIND, TWY); rilevazione diretta da parte dell'IT o degli amministratori di sistema (TD-SGI-REG003) durante le attività di monitoraggio; segnalazione esterna (Garante, CSIRT, autorità competenti). Ogni segnalazione è registrata immediatamente nel Registro degli Incidenti con un numero progressivo, la data e l'ora di rilevazione, la fonte della segnalazione e una descrizione preliminare.

4.2 Fase 2 – Triage e classificazione

L'IT effettua il triage entro i tempi previsti dal livello di severità: identifica la tipologia dell'incidente (Sezione 3.1), assegna il livello di severità (P1-P4), valuta se l'incidente coinvolge dati personali (potenziale data breach) e attiva la catena di escalation corrispondente. Se l'incidente è classificato P1 o P2, l'IT contatta immediatamente il fornitore SaaS del sistema coinvolto per attivare il supporto di secondo livello.

4.3 Fase 3 – Contenimento

Le misure di contenimento sono proporzionate alla severità e alla tipologia dell'incidente:

- Malware/ransomware: isolamento immediato della postazione dalla rete (disconnessione cavo o disattivazione Wi-Fi); blocco dell'account compromesso su Azure AD; scansione antivirus forzata; verifica della diffusione ad altre postazioni.
- Phishing / compromissione account: reset immediato della password dell'account compromesso; revoca delle sessioni attive su M365; verifica delle regole di inoltro email e delle app autorizzate; comunicazione al personale per prevenire ulteriori click.
- Accesso non autorizzato: blocco dell'account o dell'IP sorgente; revisione dei log di accesso; verifica dell'estensione dell'accesso (quali dati e sistemi sono stati raggiunti).
- Indisponibilità del servizio: attivazione della connettività di backup WIND (se guasto di rete); attivazione delle procedure manuali di fallback per il sistema coinvolto (PRO016 Sez. 10); comunicazione al personale operativo e ai pazienti se necessario.

– Data breach: preservazione delle evidenze (non cancellare log, non spegnere sistemi salvo necessità); notifica immediata al DPO; avvio della valutazione dell'impatto sui diritti e le libertà degli interessati.

4.4 Fase 4 – Indagine e analisi

L'IT conduce l'indagine in collaborazione con il fornitore SaaS coinvolto e, per gli incidenti P1-P2, con il supporto dell'RSGI. L'indagine comprende: l'analisi cronologica dell'evento (timeline); l'identificazione del vettore di attacco o della causa tecnica; la valutazione dell'estensione del danno (sistemi coinvolti, dati compromessi, durata dell'impatto); l'analisi dei log (access log degli AdS, log di sistema, log del firewall, log applicativi); la correlazione con eventuali modifiche recenti (collegamento con il Registro delle Modifiche IT, TD-SGI-PRO018 Sez. 7).

4.5 Fase 5 – Ripristino

Il ripristino è coordinato dall'IT con il fornitore SaaS responsabile:

- Sistemi SaaS (GIPOnext, StudioLab, ZeeroMED): il ripristino è effettuato dal fornitore dal proprio ambiente cloud, entro i tempi RTO contrattuali (TD-SGI-PRO016 Sez. 10). L'IT monitora il processo e verifica la disponibilità del servizio dopo il ripristino.
- Microsoft 365: ripristino tramite gli strumenti nativi di Azure (ripristino mailbox, ripristino file da versioning SharePoint/OneDrive, ripristino account da cestino Azure AD).
- Infrastruttura di rete (WIND): ripristino della connettività tramite il partner WIND, con failover automatico sulla linea di backup. Per guasti di apparati locali, sostituzione entro gli SLA contrattuali.
- Postazioni di lavoro: reimaging della postazione compromessa; ripristino dei dati da OneDrive/SharePoint. Per infezioni da ransomware, la postazione è formattata e ricreata da zero.

Prima di dichiarare l'incidente risolto, l'IT verifica che il servizio sia completamente operativo, che le integrazioni tra sistemi funzionino correttamente (flusso GIPOnext ↔ StudioLab, GIPOnext ↔ ZeeroMED, worklist DICOM) e che non vi siano residui dell'incidente.

4.6 Fase 6 – Notifiche obbligatorie

Se l'incidente configura un data breach o un incidente significativo, si applicano le seguenti notifiche obbligatorie:

Obbligo	Destinatario	Termine	Responsabile
Notifica data breach (art. 33 GDPR)	Garante per la protezione dei dati personali	Entro 72 ore dalla scoperta (senza ingiustificato ritardo)	DPO
Comunicazione agli interessati (art. 34 GDPR)	Pazienti / soggetti i cui dati sono stati violati	Senza ingiustificato ritardo, se rischio elevato per i diritti	DPO, con supporto IT e DS
Notifica incidente significativo (NIS 2, art. 25)	CSIRT Italia (csirt@pec.acn.gov.it)	Pre-notifica entro 24 ore; notifica completa entro 72 ore; relazione finale entro 1 mese	IT / RSGI
Comunicazione interna	AD, DS, RSGI, DPO	Immediata per P1-P2; entro 4 ore per P3	IT
Segnalazione al fornitore SaaS	Fornitore del sistema coinvolto	Immediata	IT

La notifica al Garante non è necessaria se è improbabile che la violazione presenti un rischio per i diritti e le libertà delle persone fisiche. La valutazione è effettuata dal DPO in collaborazione con l'IT e documentata nel Registro degli Incidenti anche in caso di decisione di non notifica.

4.7 Fase 7 – Chiusura, documentazione e lesson learned

L'incidente è chiuso formalmente nel Registro con la documentazione completa:

- Rapporto di incidente: cronologia dettagliata (dalla rilevazione alla chiusura); tipologia e severità; sistemi e dati coinvolti; causa radice (root cause); misure di contenimento adottate; azioni di ripristino; impatto effettivo (durata del disservizio, numero di utenti e pazienti impattati, dati compromessi); notifiche effettuate; costo stimato dell'incidente.
- Lesson learned: analisi delle cause profonde e dei fattori contribuenti; identificazione delle misure preventive per evitare il ripetersi dell'incidente; eventuali modifiche alle procedure, alle configurazioni o alla formazione.
- Azioni correttive: registrate con responsabile, scadenza e verifica di efficacia. Le azioni che richiedono una modifica ai sistemi sono gestite come RFC tramite la TD-SGI-PRO018.
- Presentazione al Riesame: gli incidenti P1 e P2 sono presentati individualmente al Riesame della Direzione (TD-SGI-PRO002). Gli incidenti P3 e P4 sono presentati in forma aggregata (analisi dei trend).

5. Catena di escalation

La catena di escalation definisce chi è informato e quando, in funzione della severità:

Livello	IT	RSGI + DPO	DS	AD
P1 – Critico	Immediato. Coordinamento h24	Immediato	Immediato	Immediato
P2 – Alto	Immediato	Entro 1 ora	Entro 2 ore (se impatto clinico)	Entro 4 ore
P3 – Medio	Entro 2 ore	Entro 4 ore	Solo se impatto clinico	Report periodico
P4 – Basso	Entro 4 ore lav.	Report mensile	N/A	Report periodico

6. Procedure manuali di fallback

In caso di indisponibilità prolungata di un sistema clinico core, Toscana Diagnostica attiva le procedure manuali di fallback per garantire la continuità delle prestazioni essenziali:

Sistema indisponibile	Procedura di fallback
GIPOnext (accettazione)	Accettazione manuale su modulo cartaceo con dati anagrafici, prestazione richiesta, medico prescrivente. Registrazione nel sistema al ripristino. Comunicazione ai pazienti in attesa
StudioLab (LIS)	Registrazione manuale dei prelievi su foglio di lavoro cartaceo. Etichettatura manuale delle provette. Caricamento nel LIS al ripristino. Comunicazione dei valori critici tramite telefono e annotazione cartacea
ZeeroMED (RIS/PACS)	Esecuzione degli esami con registrazione manuale. Archiviazione temporanea delle immagini sul disco locale della modalità DICOM. Invio al PACS al ripristino. Refertazione differita
Microsoft 365 (posta)	Comunicazioni urgenti tramite telefono e messaggistica mobile. Accesso alla posta tramite dispositivi mobili personali se il guasto è limitato alle postazioni
WIND (rete)	Failover automatico sulla linea di backup. Se entrambe le linee sono indisponibili: operatività locale con dati cached, nessun accesso ai sistemi cloud, procedure manuali complete

7. Contatti di emergenza

L'IT mantiene aggiornato l'elenco dei contatti di emergenza per la gestione degli incidenti:

Soggetto	Riferimento	Reperibilità	Canale
IT interno Toscana Diagnostica	Responsabile IT (da indicare)	Lun-Sab orario operativo + reperibilità	Telefono, Teams, email
WIND – NOC (Network Operations Center)	Numero dedicato da contratto	24/7/365	Telefono, portale ticketing
CB Sistemi – Supporto StudioLab	Numero dedicato da contratto	Lun-Sab orario esteso	Telefono, email, remote
DocPlanner – Supporto GIPOnext	Numero dedicato da contratto	Lun-Sab orario esteso	Telefono, email, portale
ZeeroMED – Supporto RIS/PACS	Numero dedicato da contratto	Lun-Sab orario esteso	Telefono, email, remote
TWY – Supporto fonia	Numero dedicato da contratto	Lun-Ven orario ufficio	Telefono, email
Microsoft – Supporto Premier/Unified	Portale admin.microsoft.com	24/7 per severità A (Critica)	Portale, telefono
DPO Toscana Diagnostica	(da indicare)	Reperibile per data breach	Telefono, email
CSIRT Italia	csirt@pec.acn.gov.it	24/7	PEC, portale
Garante Privacy	protocollo@pec.gpdp.it	Ufficio	PEC (notifica data breach)

8. Matrice delle responsabilità (RACI)

R = Responsabile, A = Approvatore, C = Consultato, I = Informato.

Attività	IT	RSGI	DPO	DS	Fornit.	AD
Rilevazione e segnalazione	R	I	I	I	C	I
Triage e classificazione	R	C	C	I	C	I
Contenimento	R	I	I	I	R	I
Indagine e analisi	R	C	C	C	R	I
Ripristino	R	I	I	I	R	I
Notifica Garante (data breach)	C	C	R	I	I	A
Notifica CSIRT (NIS 2)	R	R	C	I	I	A
Comunicazione agli interessati	C	C	R	C	I	A
Attivazione fallback clinico	C	C	I	R	I	I
Rapporto e lesson learned	R	C	C	I	C	I
Azioni correttive post-incidente	R	A	C	C	C	I

9. Indicatori di processo

Tempo medio di presa in carico (per livello di severità): Obiettivo: entro i tempi target della Sezione 3.2.

Tempo medio di risoluzione (MTTR, per livello): Obiettivo: entro i tempi target. P1 ≤ 2h, P2 ≤ 4h, P3 ≤ 8h lav., P4 ≤ 2gg lav.

Numero di incidenti per trimestre (per tipologia e severità): Monitoraggio trend. Obiettivo: riduzione progressiva.

Data breach notificati al Garante: numero per anno. Obiettivo: zero.

Incidenti con impatto sull'operatività clinica: numero di incidenti P1-P2 che hanno causato interruzione del servizio diagnostico. Obiettivo: zero.

Azioni correttive post-incidente chiuse nei termini: percentuale. Obiettivo: ≥ 95%.

Test annuale di ripristino (DR) completati: numero per sistema critico. Obiettivo: 1 per sistema per anno (rif. PRO016 Sez. 10).

Tasso di incidenti derivanti da phishing: correlazione con le campagne di phishing simulato (PRO016 Sez. 12). Obiettivo: riduzione progressiva.

10. Storico delle revisioni

Rev.	Data	Descrizione modifiche	Approvazione
00	12/04/2026	Prima emissione	Francesco Epifani